



**HOGESCHOOL
UTRECHT**



COMPLIANCE STANDAARDEN



Index

- Inleiding _____ 4-5
 - Wat is compliance?
 - Waarom is compliance belangrijk?
 - Belangrijke terminologie
- Door wie worden compliance standaarden ontwikkeld? _____ 5
 - ISO (International Organization for Standardization)
 - NIST (National Institute of Standards and Technology)
 - CIS (Center for Internet Security)
 - GDPR (General Data Protection Regulation / AVG)
- Hoe passen ze op organisaties en systemen? _____ 5
- ISO/IEC 27001 – Informatiebeveiligingsmanagement _____ 5-6
 - Doel
 - Belangrijke principes of maatregelen
 - Hoe het de beveiliging verbetert
 - Toepassing van ISO/IEC 27001 op Besturingssystemen
- NIST SP 800-53 – Security and Privacy Controls _____ 7-8
 - Doel
 - Belangrijke principes of maatregelen
 - Hoe het de beveiliging verbetert
 - Toepassing van NIST SP 800-53 op Besturingssystemen

- CIS Controls – Best Practices van het Center for Internet Security ——— 8-9
 - Doel
 - Belangrijke principes of maatregelen
 - Hoe het de beveiliging verbetert
 - Toepassing van CIS Controls op Besturingssystemen
- GDPR (AVG) – Algemene Verordening Gegevensbescherming ——— 9-10
 - Doel
 - Belangrijke principes of maatregelen
 - Hoe het de beveiliging verbetert
 - Toepassing van de GDPR (AVG) op Besturingssystemen
- Conclusie ————— 10
- Bronnenlijst ————— 10-11

Inleiding

In een steeds complexere en digitaal verbonden wereld is het naleven van wet- en regelgeving van cruciaal belang. Organisaties moeten voldoen aan uiteenlopende eisen op het gebied van privacy, informatiebeveiliging en ethisch handelen. Dit wordt samengevat onder de noemer compliance. In dit verslag wordt uitgelegd wat compliance inhoudt, waarom het belangrijk is, en welke internationale standaarden hierbij een rol spelen. Ook wordt toegelicht hoe deze standaarden toegepast kunnen worden op besturingssystemen zoals Windows en Linux.

Wat is compliance?

Compliance betekent dat een persoon, organisatie of bedrijf zich houdt aan wetten, regels, normen en gedragsrichtlijnen die van toepassing zijn op hun activiteiten. Dit kan zowel externe regelgeving betreffen (zoals wetgeving van de overheid of brancheorganisaties) als interne beleidsregels binnen een organisatie.

Waarom is compliance belangrijk?

Compliance is essentieel om juridische problemen, boetes en reputatieschade te voorkomen. Organisaties die compliant zijn, tonen aan dat zij op een verantwoorde, transparante en betrouwbare manier werken. Het bevordert ethisch gedrag, versterkt het vertrouwen van klanten en stakeholders, en draagt bij aan een gezonde en eerlijke werkomgeving.

Belangrijke terminologie

- **Wet- en regelgeving:** De formele wetten en regels die opgelegd zijn door overheden of toezichthouders.
- **Norm (standaard):** Een richtlijn die aangeeft wat als goede of best practice wordt beschouwd, vaak opgesteld door professionele of internationale organisaties.
- **Beleid:** De interne regels en procedures van een organisatie die bepalen hoe medewerkers moeten handelen.
- **Audit:** Een systematische controle om na te gaan of de organisatie zich aan de regels en standaarden houdt.
- **Toezicht (governance):** Het proces waarmee gecontroleerd wordt of compliance gewaarborgd blijft binnen een organisatie.

Compliance kan in veel domeinen van toepassing zijn, zoals:

- **Financiële sector:** Bijvoorbeeld voldoen aan anti-witwasregelgeving.
- **Gezondheidszorg:** Voldoen aan privacywetgeving zoals de AVG (GDPR).
- **Arbeidsrecht:** Regels rond werktijden, veiligheid, en gelijke behandeling.
- **Milieu:** Duurzaamheidsregels en milieuwetgeving.

Door wie worden compliance standaarden ontwikkeld?

Compliance standaarden worden opgesteld en gehandhaafd door nationale en internationale organisaties of overheidsinstanties. Enkele belangrijke voorbeelden zijn:

- ISO (International Organization for Standardization): Ontwikkelt wereldwijde normen zoals ISO/IEC 27001 voor informatiebeveiliging.
- NIST (National Institute of Standards and Technology): Publiceert technische richtlijnen zoals NIST SP 800-series voor cybersecurity.
- CIS (Center for Internet Security): Biedt praktische beveiligingsmaatregelen in de vorm van CIS Controls.
- GDPR (General Data Protection Regulation / AVG): Europese privacywetgeving die regels oplegt voor het verwerken van persoonsgegevens.

Hoe passen ze op organisaties en systemen?

Compliance standaarden worden toegepast op verschillende onderdelen van een organisatie, zoals IT-systemen, personeelsbeleid, financiële processen en klantgegevens. Ze helpen bij het opstellen van beleidsregels, implementeren van technische maatregelen (zoals toegangscontrole of encryptie), en het organiseren van audits en risicobeoordelingen. Afhankelijk van het type organisatie en sector kunnen bepaalde standaarden verplicht zijn of als best practice gelden.

1. ISO/IEC 27001 – Informatiebeveiligingsmanagement

Doel

ISO/IEC 27001 is een internationale norm die richtlijnen biedt voor het opzetten, implementeren en verbeteren van een Information Security Management System (ISMS). Het doel is om gevoelige informatie systematisch te beveiligen.

Belangrijke principes of maatregelen

- Risicobeoordeling en -beheer
- Beleidsvorming voor informatiebeveiliging
- Toegangscontrole
- Beheer van incidenten
- Regelmatige audits en verbetercycli (PDCA)

Hoe het de beveiliging verbetert

De standaard helpt organisaties om beveiligingsrisico's te identificeren, beheren en verminderen. Het creëert bewustwording en maakt beveiliging onderdeel van het bedrijfsproces.

ISO/IEC 27001 – Toepassing op besturingssystemen

Windows

- **Gebruik van Groepsbeleid (Group Policy):** Groepsbeleid kan worden ingezet om toegangsrechten van gebruikers te beperken. Dit helpt bij het afdwingen van het principe van minimale bevoegdheden, wat een belangrijk aspect is van informatiebeveiliging.
- **Inschakelen van encryptie via BitLocker:** BitLocker biedt volledige schijfversleuteling, wat cruciaal is om gegevens te beschermen tegen ongeautoriseerde toegang, vooral bij verlies of diefstal van hardware.

Linux

- **Beheer van toegangsrechten met chmod en chown:** Door het gebruik van deze commando's kunnen toegangsrechten tot bestanden en mappen nauwkeurig worden ingesteld en beheerd, wat helpt bij het beschermen van gevoelige informatie.
- **Configureren van automatische updates via apt of dnf:** Door automatische updates in te schakelen via pakketbeheerders zoals apt (voor Debian-gebaseerde systemen) of dnf (voor Fedora-gebaseerde systemen), kunnen beveiligingspatches snel en betrouwbaar worden toegepast.

2. NIST SP 800-53 – Security and Privacy Controls

Doel

Deze Amerikaanse standaard van NIST bevat een uitgebreide set beveiligings- en privacymaatregelen voor informatiesystemen, voornamelijk gebruikt door overheidsinstellingen.

Belangrijke principes of maatregelen

- 20+ families van beveiligingscontroles (bijv. toegangsbeheer, incidentrespons, encryptie)
- Flexibel toepasbaar op verschillende risiconiveaus
- Integreert privacy en beveiliging

Hoe het de beveiliging verbetert

De standaard biedt een raamwerk dat helpt om systemen te beschermen tegen cyberdreigingen. Het is schaalbaar en toepasbaar in zowel kleine als grote omgevingen.

Toepassing van NIST SP 800-53 op Besturingssystemen

Windows

- **Accountvergrendeling configureren:** Door instellingen voor accountvergrendeling te configureren, kunnen brute force-aanvallen worden voorkomen. Na een bepaald aantal mislukte inlogpogingen wordt het account tijdelijk geblokkeerd, wat de kans op ongeautoriseerde toegang vermindert.
- **Windows Defender Antivirus en Firewall inschakelen:** Het activeren van Windows Defender biedt realtime bescherming tegen malware, terwijl de ingebouwde firewall helpt bij het beheren van netwerkverkeer en het blokkeren van ongewenste verbindingen.

Linux

- **Gebruik van SELinux of AppArmor voor toegangscontrole:** Deze beveiligingsmodules bieden een extra laag toegangscontrole bovenop traditionele bestandsrechten. Ze beperken welke processen toegang hebben tot welke middelen, en beschermen zo tegen privilege escalation en andere aanvallen.

- **Firewallconfiguratie met iptables of ufw:** Firewalls zoals iptables of het eenvoudiger te gebruiken ufw (Uncomplicated Firewall) helpen bij het beperken van netwerktoegang tot alleen vertrouwde verbindingen, wat een belangrijk onderdeel is van netwerkbeveiliging.

3. CIS Controls – Best Practices van het Center for Internet Security

Doel

CIS Controls zijn een reeks praktische acties die organisaties kunnen nemen om hun cyberweerbaarheid te versterken. Ze zijn gericht op prioriteiten en eenvoud.

Belangrijke principes of maatregelen:

- 18 kerncontroles, verdeeld in drie niveaus (basic, foundational, organizational)
- Beheer van hardware en software
- Systeem- en netwerkbeveiliging
- Continue monitoring

Hoe het de beveiliging verbetert

Door zich te richten op de meest voorkomende aanvalspaden, bieden de CIS Controls direct toepasbare beveiligingsmaatregelen voor zowel kleine als grote organisaties

Toepassing van CIS Controls op Besturingssystemen

Windows

- **Inventarisatie van actieve software met PowerShell-scripts:** Het regelmatig uitvoeren van PowerShell-scripts helpt bij het verkrijgen van een actueel overzicht van alle geïnstalleerde en actieve software. Dit ondersteunt controle over ongeautoriseerde of verouderde applicaties.
- **Uitschakelen van ongebruikte poorten via Windows Firewall:** Door ongebruikte netwerkpoorten te blokkeren in de Windows Firewall wordt het aanvalsooppervlak verkleind en wordt voorkomen dat diensten onbedoeld bereikbaar zijn.

Linux

- **Verwijderen van ongebruikte software met apt of yum:** Niet-essentiële softwarepakketten kunnen worden verwijderd met behulp van pakketbeheerders zoals apt (Debian/Ubuntu) of yum (CentOS/RHEL). Dit minimaliseert kwetsbaarheden door het beperken van de software die onderhouden moet worden.
- **Beperken van SSH-toegang tot specifieke gebruikers:** Door alleen specifieke gebruikers toe te staan om via SSH verbinding te maken, wordt de toegang tot systemen strikter gecontroleerd en wordt het risico op misbruik van inloggegevens verkleind.

4. GDPR (AVG) – Algemene Verordening Gegevensbescherming

Doel

De GDPR is een Europese wetgeving die de privacy en bescherming van persoonsgegevens regelt. Het doel is om individuen controle te geven over hun gegevens.

Belangrijke principes of maatregelen:

- Transparantie en doelbinding
- Minimale gegevensverwerking
- Rechten van betrokkenen (zoals inzage, correctie, verwijdering)
- Meldplicht bij datalekken
- Privacy by design & by default

Hoe het de beveiliging verbetert

De AVG verplicht organisaties om persoonsgegevens goed te beschermen, wat leidt tot betere beveiligingsmaatregelen, bewustzijn en verantwoordelijkheid binnen de organisatie.

Toepassing van de GDPR (AVG) op Besturingssystemen

Windows

- **Beperken van toegang tot persoonsgegevens via bestandsrechten:** Door NTFS-rechten correct in te stellen, kunnen alleen bevoegde gebruikers toegang krijgen tot mappen en bestanden met gevoelige gegevens. Dit ondersteunt de naleving van het 'need-to-know'-principe.

- **Encryptie van gebruikersdata met BitLocker:** BitLocker versleutelt harde schijven zodat persoonsgegevens niet leesbaar zijn bij verlies of diefstal van het apparaat. Dit voldoet aan de GDPR-eis voor gegevensbeveiliging bij opslag.

Linux

- **Encryptie van home directories en databases:** Door versleuteling toe te passen op gebruikersmappen en databases, worden persoonsgegevens beschermd tegen ongeautoriseerde toegang bij fysieke of digitale inbreuken.
- **Gebruik van sudo om toegang tot gevoelige data te beperken:** Door toegang tot root-rechten te beperken via sudo, wordt voorkomen dat onbevoegde gebruikers systeem- of gegevensbeheerfuncties kunnen uitvoeren.

Conclusie

Compliance is een onmisbaar onderdeel van moderne bedrijfsvoering. Door te voldoen aan relevante wet- en regelgeving, standaarden en interne beleidsregels tonen organisaties aan dat zij verantwoord, veilig en transparant opereren. Standaarden zoals ISO/IEC 27001, NIST SP 800-53, CIS Controls en de AVG (GDPR) bieden duidelijke kaders voor het beschermen van informatie, het waarborgen van privacy en het beheersen van risico's. De toepassing van deze standaarden op besturingssystemen zoals Windows en Linux laat zien hoe compliance ook op technisch niveau wordt doorgevoerd. Door middel van maatregelen zoals toegangsbeheer, logging, encryptie en automatische updates kunnen systemen beter beveiligd worden tegen dreigingen. Het naleven van compliance standaarden is niet alleen een verplichting, maar ook een investering in vertrouwen, veiligheid en de continuïteit van de organisatie.

Bronnenlijst

- **Wikipedia. Compliance**
 - [https://nl.wikipedia.org/wiki/Compliance_\(regelgeving\)](https://nl.wikipedia.org/wiki/Compliance_(regelgeving))
 - https://en.wikipedia.org/wiki/ISO/IEC_27001
 - https://en.wikipedia.org/wiki/NIST_Cybersecurity_Framework
 - https://en.wikipedia.org/wiki/General_Data_Protection_Regulation
 - https://en.wikipedia.org/wiki/The_CIS_Critical_Security_Controls_for_Effective_Cyber_Defense

- **What is Compliance and why is it important?**
 - <https://youtu.be/TE4UW7MXBGc?si=dMPFxfhUZY6ZhqLGn>
- **What is ISO 27001? | A Brief Summary of the Standard**
 - <https://youtu.be/x792wXSeAhA?si=88AwWWu1LJIM6MJM>
- **NIST SP 800–53, Revision 5 Security Controls for Information Systems and Organizations – 1 overview**
 - <https://youtu.be/hWWILCZbDho?si=l7vS7p9CHp7NXJ3W>
- **Center for Internet Security (CIS) Introduction**
 - https://youtu.be/bVxa7gu1EH4?si=ZEGJTVM66zmV2_tw
- **AVG | GDPR | De basis van de Algemene Verordening Gegevensbescherming**
 - <https://youtu.be/YZtZP6X81aQ?si=QSf-qXuxbfzAqFku>